

**НЕКОММЕРЧЕСКОЕ АКЦИОНЕРНОЕ ОБЩЕСТВО
«КАЗАХСКИЙ НАЦИОНАЛЬНЫЙ ПЕДАГОГИЧЕСКИЙ
УНИВЕРСИТЕТ ИМЕНИ АБАЯ»**



УТВЕРЖДЕНО

Решением Правления

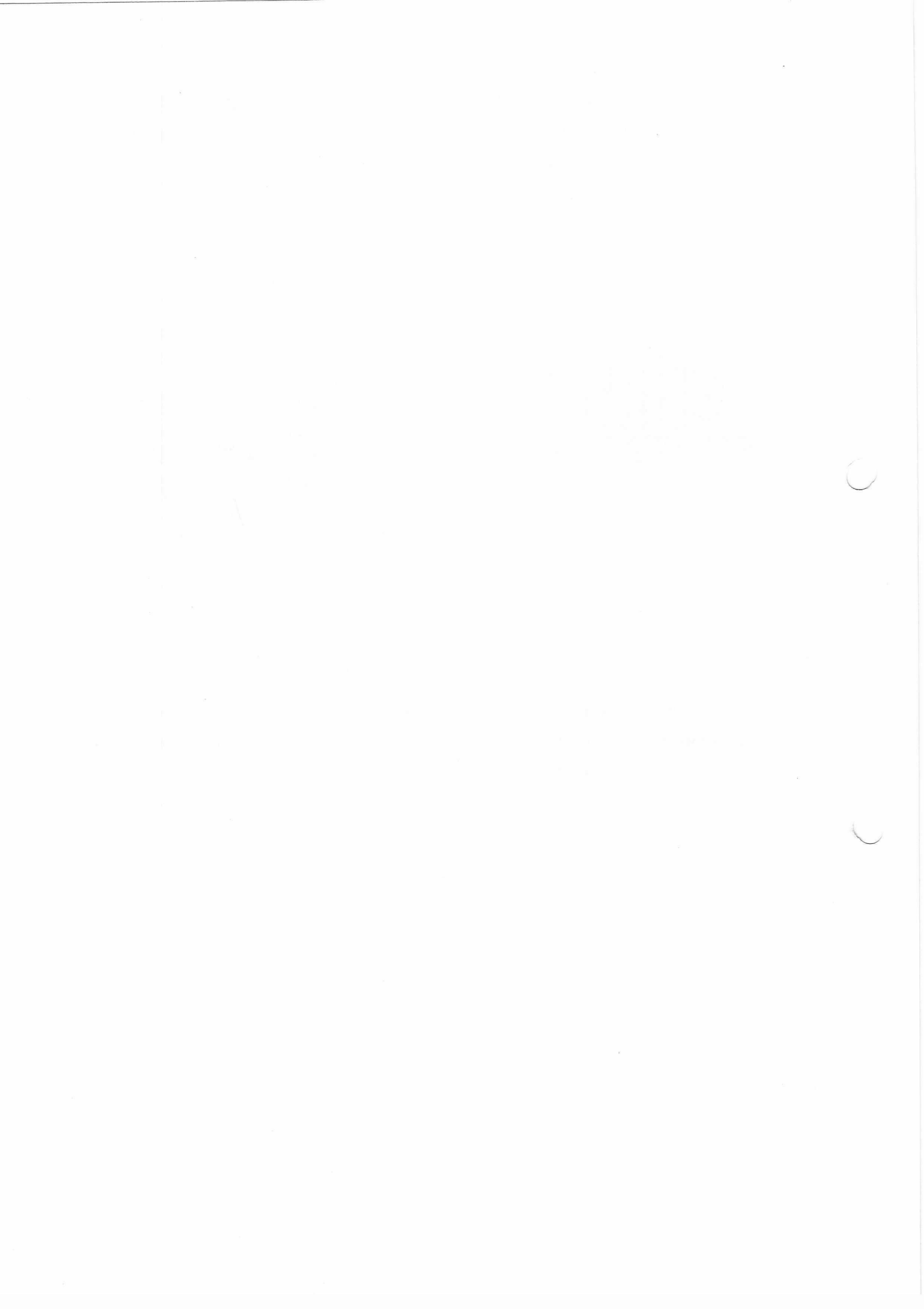
НАО «Казахский национальный
педагогический университет
имени Абая»

от «15» сентября 2025 года

Протокол № БСК/АРМА
Председатель Правления - Ректор
Тілеп Б.А.



**Методика оценки рисков информационной безопасности
Некоммерческого акционерного общества «Казахский национальный
педагогический университет имени Абая»**



Оглавление

1 Общие положения.....	3
2 Нормативная основа	3
3 Методика оценки рисков информационной безопасности.....	3
4 Методика проведения оценки рисков.....	5
5 Мониторинг рисков.....	6
6 Ответственность.	7
Лист согласования.....	8

1 Общие положения

1.1 Настоящая Методика оценки рисков информационной безопасности Некоммерческого акционерного общества «Казахский национальный педагогический университет имени Абая» (далее — Правила) разработаны в соответствии с требованиями законодательства и стандартов Республики Казахстан в области информационной безопасности.

1.2 Основной целью Методики является предоставление структурированного и унифицированного процесса оценки рисков ИБ, направленного на минимизацию их негативного воздействия на информационные активы университета. Документ был разработан с учетом установленных стандартов, нормативных требований РК и внутренних регламентов университета.

1.3 В настоящих Правилах используются следующие основные термины и сокращения:

ИТ-инфраструктура – совокупность информационных технологий, аппаратных и программных средств, сетевых ресурсов и процессов, которые обеспечивают функционирование и поддержку информационных систем университета;

ИБ – Информационная безопасность;

ПО – программное обеспечение;

ОС – Операционная система;

Администратор - сотрудник, отвечающий за настройку, оптимизацию и обслуживание ИТ-инфраструктуры университета;

Пользователь – Пользователь информационной системы;

Риск - вероятность угрозы информационной безопасности.

2 Нормативная основа

Настоящий документ разработан в соответствии со следующими нормативно-правовыми актами и документами:

- Постановление Правительства Республики Казахстан от 20.12.2016г. №832 «Об утверждении единых требований в области информационно-коммуникационных технологий и обеспечения информационной безопасности»;

3. Методика оценки рисков информационной безопасности

3.1 Область анализа определяется с учетом объектов информационной безопасности, таких как информационные системы, технические средства, программное обеспечение, данные, пользователи и процессы. В рамках оценки необходимо учитывать как внутренние, так и внешние угрозы, включая возможные инциденты, способные нанести ущерб университету. Алгоритм оценки рисков информационной безопасности представлен на Рисунке 1.



3.2 Активы университета классифицируются следующим образом:

- Критические активы – активы, нарушение безопасности которых приводит к серьезным последствиям для ключевых процессов и функционирования университета. Например, серверы баз данных, системы электронного документооборота, конфиденциальная информация.

- Средние по критичности активы – активы, нарушение безопасности которых может временно затруднить выполнение задач, но не оказывает критического влияния. Например, вспомогательные сервисы или пользовательские рабочие станции.

- Низкие по критичности активы – активы, нарушение безопасности которых минимально влияет на деятельность университета. Например, общественные веб-сайты или информационные материалы общего доступа.

В рамках этапа определения типа актива активы делятся на материальные (обозначение – A_m) и нематериальные (обозначение – A_{nm}) активы и приведены в таблицах №8 и №9 приложения 1 к настоящей Методике. Данные об активах актуализируются два раза в год, а ответственный за ИБ разрабатывает сводный перечень активов с указанием степени важности по бальной системе согласно таблице №1, 2, 3 приложения 1 к настоящей Методике.

3.3 Для каждого актива определяются потенциальные угрозы, которые подразделяются на:

- Технические угрозы – сбои оборудования, уязвимости программного обеспечения.

- Организационные угрозы – ошибки сотрудников, несоблюдение внутренних регламентов.

- Внешние угрозы – кибератаки, действия злоумышленников, природные катастрофы.

3.4 Согласно таблице № 4 приложения 1 к настоящей Методике используя справочник типичных угроз (приложение 3 к настоящей Методике) и уязвимостей (приложение 4 к настоящей Методике) ответственный за ИБ определяет виды возможных угроз и соответствующие им уязвимости.

3.5 Согласно таблице № 5 приложения 1 к настоящей Методике ответственный за ИБ определяет наиболее вероятные угрозы, которые могут быть реализованы, при этом условное обозначение будет иметь следующую оценку:

- Если объект оснащён всеми средствами защиты, вероятность угрозы принимается за $V_{ry} = 0$.

- При наличии 50% средств защиты вероятность равна $V_{ry} = 5$.

- При отсутствии более 80% средств защиты вероятность достигает $V_{ry} = 10$.

3.6 Вероятность реализации угрозы оценивается по следующей шкале:

- Высокая вероятность – угроза может быть реализована в ближайшее время на основании текущих данных и опыта.

- Средняя вероятность – угроза может быть реализована при определенных условиях.

- Низкая вероятность – угроза маловероятна в текущих условиях.

3.7 Последствия реализации угроз классифицируются следующим образом:

- Высокий уровень последствий – значительные финансовые потери, утрата критически важной информации, остановка ключевых процессов.

- Средний уровень последствий – временные затруднения в деятельности, умеренные финансовые убытки.

- Низкий уровень последствий – минимальное влияние на деятельность университета.

3.8 Уровень риска определяется как произведение вероятности реализации угрозы на уровень последствий. Принята следующая шкала оценки:

- Высокий риск – требует немедленного принятия мер по снижению угроз.

- Средний риск – рекомендуется планирование мероприятий по снижению угроз в кратчайшие сроки.

- Низкий риск – допускается текущий мониторинг без принятия срочных мер.

3.9 Риск рассчитывается по формуле:

$$R = Si * V_{ry}$$

где:

- R – риск информационной безопасности, и формируется план по снижению риска согласно таблице № 6 приложения 1 к настоящей Методике.
- S_i – ценность актива,
- V_{ry} – вероятность реализации угрозы.

4. Методика проведения оценки рисков

4.1 Процесс оценки рисков включает следующие этапы:

- Определение области анализа и идентификация активов. На данном этапе проводится сбор информации об объектах оценки: информационных системах, данных, пользователях, технических средствах. Определяются критические для университета активы, их функции и важность для бизнес-процессов. Также фиксируются их текущие уязвимости и точки доступа.
- Идентификация и классификация угроз для каждого актива. Выявляются возможные угрозы, включая внешние (например, атаки злоумышленников, природные катастрофы) и внутренние (ошибки персонала, сбои оборудования). Каждая угроза классифицируется по её источнику, характеру и потенциальному воздействию на активы.
- Анализ вероятности реализации угроз и оценка их последствий. Для каждой угрозы определяется вероятность её реализации с учетом статистики, опыта университета и текущих условий. Также проводится оценка возможных последствий, включая материальные потери, утрату данных, репутационные риски и нарушение регламентов.
- Расчёт уровня риска и категоризация по приоритетности. На основании анализа вероятности и последствий угрозы определяется уровень риска. Риски классифицируются по приоритетности: высокие требуют немедленного реагирования, средние – планирования мероприятий по снижению, низкие – регулярного мониторинга.
- Формирование отчёта и планов по снижению риска. Результаты оценки риска информационной безопасности заполняются согласно таблице № 7 приложения 1 к настоящей Методике и направляются на рассмотрение руководству.

4.2 Методы сбора данных

- Интервью с ключевыми сотрудниками и экспертами. Проводятся встречи с руководителями подразделений, администраторами систем и другими специалистами для выявления слабых мест в процессах и системах.
- Анализ логов и технической документации. Изучаются журналы событий, отчёты о сбоях, спецификации и инструкции по работе систем для выявления уязвимостей и причин инцидентов.
- Оценка статистических данных о прошлых инцидентах. Анализируются внутренние отчёты о происшествиях, данные о частоте атак, типичных сценариях нарушений и их последствиях. Это позволяет выявить наиболее уязвимые активы и прогнозировать будущие угрозы.

5. Мониторинг рисков

5.1 Мониторинг рисков проводится на регулярной основе с учетом изменений в инфраструктуре и внешней среде. Рекомендуется пересмотр рисков не реже одного раза в год, а также после значимых изменений в ИТ-инфраструктуре.

5.2 Для оценки эффективности управления рисками используются следующие показатели:

- Количество выявленных и устранённых уязвимостей.
- Частота возникновения инцидентов информационной безопасности.
- Среднее время реагирования на угрозы.

5.3 Результаты мониторинга заполняются согласно установленной форме в приложении 1 и направляются руководству для принятия решений о корректировке мер обеспечения информационной безопасности.

6 Ответственность

- Офицер информационной безопасности – осуществляет общий надзор за соблюдением мер информационной безопасности, включая регулярный аудит выполнения требований и актуализацию нормативной базы;

- Начальник управления информационных технологий – координирует действия подразделений и сотрудников в части реализации задач, предусмотренных настоящим Каталогом, включая контроль за соблюдением сроков и полнотой выполнения работ;

- Системные администраторы – обеспечивают техническую реализацию мероприятий по защите информации, включая настройку оборудования, администрирование систем и устранение технических уязвимостей.

ЛИСТ ОЗНАКОМЛЕНИЯ

[illegible]

Алматы, 2025